

purdue-l2-area-supervisory brief

Purdue Area Supervisory Control (L2) — Cross-Vendor Threat & Detection Brief

Scope: Purdue Level 2 covers HMI panels and operator workstations sitting between L3 site operations and L1 PLC/controller hardware. Roles in scope: HMI runtime servers (WinCC RT Advanced/Professional, FactoryTalk View ME runtime, Vijeo XD runtime, Experion Station), dedicated HMI panel firmware (Siemens Comfort/Basic/Mobile/Unified panels, Rockwell PanelView Plus 6/7 and PanelView 800, Schneider Magelis HMIGTO/HMIGTU/HMIGTW), and the local operator console hardware on which those runtimes execute. Source briefs contributing material: [siemens brief](#) (Comfort/Basic/Mobile panels, WinCC RT, Unified Web Runtime), [rockwell brief](#) (PanelView family, FactoryTalk View ME), [schneider brief](#) (Vijeo Designer/XD runtime, Magelis), [honeywell brief](#) (Experion station). This brief is intentionally shorter than the L1 / L3 / L3.5 briefs because the per-vendor source material covered HMI lightly — that is honest, not a defect. **Coverage gap: HMI runtime versions are under-represented in current extraction; future firmware passes should target Comfort Panel + PanelView Plus + Magelis firmware images so this layer can move from research-only to verified-on-extract.**

Architecture grouping (organized by ROLE within this layer, not by vendor)

Class (role)	Products (cross-vendor)	Stack	Catalog depth
L2-a. Vendor HMI panel firmware (dedicated touch-panel hardware)	Siemens SIMATIC Comfort Panel TP/KP/KTP, Basic Panel, Mobile KTP, Unified Comfort Panel; Rockwell PanelView Plus 6/7, PanelView 800; Schneider Magelis HMIGTO / HMIGTU / HMIGTW / HMISTO	Vendor-locked embedded Linux or WinCE/WEC7 + vendor runtime (WinCC RT Comfort/Unified, FactoryTalk View ME runtime, Vijeo XD runtime), HTTP/HTTPS config web, VNC/SmartServer, OPC UA client	research only (see siemens brief Group B , rockwell brief Group D , schneider brief Group B)
L2-b. PC-based HMI runtime (operator workstation hosting the SCADA-thin runtime)	Siemens WinCC Runtime Advanced / Runtime Professional / Unified Web Runtime; Rockwell FactoryTalk View ME on a Windows operator PC;	Windows 10/11 / Windows Server + .NET, IIS (Unified web client), embedded SQL Express, OPC UA / OPC Classic DCOM	partially extracted (DVD1 install tree — see siemens brief Group B);

Class (role)	Products (cross-vendor)	Stack	Catalog depth
	Schneider Vijeo XD runtime on Windows		rest research only
L2-c. Operator console / control-room workstation (DCS operator station, not engineering EWS)	Honeywell Experion Station / PKS Operator Console	Windows + Experion HMI client + CDA proxy to L2 supervisory peers	research only (see honeywell brief Group A)

Group L2-a — Vendor HMI panel firmware (the cheap unmonitored beach-head)

Direct attack surface (cross-vendor, per source briefs):

```
Embedded HTTP/HTTPS config UI • VNC / SmartServer remote-view • OPC UA client to PLCs •
Modbus TCP/502 client • S7comm / EtherNet-IP client • USB host port on panel •
SD/CF card slot (project file load) • vendor-proprietary "transfer" service (project download)
```

HMI panels are the most-forgotten OT asset class: rarely patched, often on a flat OT VLAN, and trusted by L1 PLCs because they speak the native protocol (S7comm, CIP, UMAS, Modbus). A compromised panel is a *legitimate* protocol-speaker that can issue writes the operator sees as their own.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
Siemens ProductCERT — WinCC Unified Web Runtime advisory class	8.x	Siemens	Unified Comfort Panel (Unified Web Runtime)	Path traversal in Unified Web Runtime
ICSA-23-193-01 — FactoryTalk View ME family	varies	Rockwell	PanelView Plus 6/7 running FactoryTalk View ME runtime	Multiple unauth issues against ME runtime
CVE-2024-45824	9.8	Rockwell	FactoryTalk View ME runtime (PanelView host)	Remote code injection via crafted project

Top attack vector (MITRE ATT&CK ICS): [T0832 Manipulation of View](#) — tamper the tag mapping or screen content so what the operator sees diverges from what the L1 controller is actually doing.

Chains directly into a parallel L1 write that goes unnoticed.

Group L2-b — PC-based HMI runtime (Windows operator PC)

Direct attack surface (cross-vendor, per source briefs):

```
WinCC CCEServer/CCAgent services · WinCC Unified web client (HTTPS/443) ·  
FactoryTalk View ME runtime + FT Linx broker (TCP/3060 + dynamic) · Vijeo XD runtime + OPC client ·  
embedded MSSQL Express backend · OPC UA server (TCP/4840) · IIS web for browser-served HMI
```

This is where classic-WinCC is still the most-CVE'd HMI on the market (Stuxnet's original target), and where Unified's move to a browser-served runtime has introduced fresh XSS / auth-bypass classes. FactoryTalk View ME runtime running on a kiosk Windows box exposes the same FactoryTalk Services Platform CVE surface as a full SCADA server.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
Siemens ProductCERT — WinCC web-client auth advisory class	9.x	Siemens	WinCC Runtime (web client)	Improper auth in WinCC web client
Siemens ProductCERT — WinCC Unified Web Runtime advisory class	8.x	Siemens	WinCC Unified Web Runtime	Path traversal in Unified Web Runtime
Siemens ProductCERT — WinCC installer DLL-hijack advisory class	7.8	Siemens	WinCC Runtime	DLL hijack on installation
Stuxnet (historical)	n/a	Siemens	WinCC	Hardcoded MSSQL credential + <code>s7otbxdx.dll</code> hijack
CVE-2024-21915	9.8	Rockwell	FactoryTalk Service Platform (touches View ME runtime auth)	Privilege escalation across FT user store (ICSA-24-018-01)
CVE-2024-21914	6.5	Rockwell	FactoryTalk View (SE/ME)	DoS via crafted message (ICSA-24-018-02)
CVE-2024-45824	9.8	Rockwell	FactoryTalk View ME runtime	Remote code injection via crafted project

CVE	CVSS	Vendor	Product	Vector
ICSA-23-193-01 — FactoryTalk View ME family	varies	Rockwell	FactoryTalk View ME	Multiple unauth issues
CVE-2020-7559	7.8	Schneider	EcoStruxure / Vijeo Designer (DLL-hijack class also affects Vijeo runtime host)	DLL hijack at runtime startup

Top attack vector (MITRE ATT&CK ICS): [T0859 Valid Accounts](#) on the HMI runtime's MSSQL/FT user store (Stuxnet's path), paired with [T0832 Manipulation of View](#) by tampering tag values displayed to the operator.

Group L2-c — Operator console (DCS operator station)

Direct attack surface (per [honeywell brief Group A](#)):

Experion Station is the operator-facing window into the C300 / C200E DCS — a Windows host running the Experion HMI client and a CDA proxy to L2 supervisory peers (CDA = Control Data Access, UDP/55555). It inherits the ICEFALL trust model: the protocol authenticates the channel, the firmware does not authenticate the payload.

Confirmed CVEs across vendors:

CVE	CVSS	Vendor	Product	Vector
ICSA-23-061-02	Critical (9.x)	Honeywell	Experion PKS / LX / PlantCruise (station + controller)	ICEFALL "Crystallized Insecurity" — CDA memory corruption + auth-bypass affects station-side handler
CVE-2021-38397	10.0	Honeywell	Experion PKS / LX / PlantCruise (engineering + station hosts)	Unrestricted file upload → unauth RCE
CVE-2021-38395	9.1	Honeywell	Experion PKS / LX / PlantCruise	Argument injection in a Honeywell-signed binary
ICSA-21-294-02	Critical	Honeywell	Experion PKS Server / engineering + station host	Upload / argument-injection / DLL-hijack cluster

Top attack vector (MITRE ATT&CK ICS): [T0859 Valid Accounts](#) — `OperatorLogin` followed by `PointParameterChange` from a station that should be read-only is the classic Experion abuse pattern.

Logging matrix (highest priority for this layer)

Top 8 — cross-vendor, ordered by detection value per ingest dollar:

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	HMI runtime audit (WinCC / FactoryTalk Diagnostics / Experion Operator Action Journal)	User logon failed x N then success, or Project loaded outside maintenance window	Brute force / unauthorised project load on HMI runtime	T0812 Default Credentials
2	HMI runtime audit	OperatorLogin → PointParameterChange / Tag Write from non-engineering station	Operator-account abuse, tag tamper	T0859 Valid Accounts
3	Network IDS (Zeek/Suricata)	OPC UA WriteValue to WinCC/FactoryTalk/Vijeo tags from a non-HMI host	Bypassing the HMI to drive tags directly	T0836 Modify Parameter
4	Network IDS	S7comm / CIP / UMAS / Modbus write originating from an HMI panel IP to L1 PLC outside the panel's commissioned tag set	Compromised panel speaking legitimate protocol	T0832 Manipulation of View + T0831 Manipulation of Control
5	Sysmon on HMI runtime PC	EventID 7 ImageLoad — non-vendor DLLs loaded by CCEServer.exe / ViewSE*.exe / Vijeo*.exe / Experion HMI client	DLL-hijack class (WinCC installer DLL-hijack, CVE-2020-7559 Vijeo class)	T1574.001 (Enterprise)
6	Sysmon on HMI runtime PC	EventID 1 ProcessCreate where ParentImage = HMI runtime AND child = cmd.exe / powershell.exe / rundll32.exe	Runtime exploitation (CVE-2024-45824 FT View ME RCE, WinCC web auth-bypass)	T1059 (Enterprise)
7	HMI panel syslog / SmartServer log	VNC / SmartServer session from non-operator subnet; new web-UI admin account; firmware-upload event on a panel	Panel as cheap unmonitored beach-head	T0857 System Firmware

#	Source	Event	What it catches	MITRE ATT&CK ICS
8	Honeywell Experion CDAEvent / system event journal	CDA UDP/55555 traffic from station to supervisory peer outside expected pairing	ICEFALL CDA lateral movement out of L2	T0843 Program Download

Secondary:

- Firewall: HMI panels and operator PCs should never originate outbound traffic to non-RFC1918 — any panel egress to the internet is a foothold signal.
- Enable WinCC audit + security + firmware-update categories; FactoryTalk Diagnostics Audit + Security + Configuration categories; Experion Operator Action Journal + System Event Journal — forward all to SIEM.
- Watch for "tag write outside operator shift window" — an HMI-driven setpoint at 03:00 with no scheduled operator on shift is high-fidelity for [T0836 Modify Parameter](#).

Cross-layer pivots

1. **L2 HMI tamper → operator deception (Manipulation of View) while parallel L1 action proceeds unseen.** Attacker rewrites WinCC/FactoryTalk View ME/Vijeo tag mappings so the operator sees nominal values while a parallel S7comm/CIP/UMAS session from the same panel pushes off-spec setpoints to the L1 PLC. Classic Stuxnet shape; still works on any HMI runtime where tag mapping is locally cacheable. Detection lives in row 4 of the logging matrix.
2. **L2 → L1 via OPC / Modbus / native protocol from a compromised HMI runtime.** The HMI runtime is a *legitimate* protocol speaker — any RCE on the HMI PC (CVE-2024-45824, WinCC Unified path traversal, Vijeo DLL hijack) becomes unauthenticated CIP/S7comm/UMAS/Modbus writes against L1 from a source IP the controller trusts. No L1 CVE required; the HMI is the on-ramp.
3. **L2 → L3 via the SCADA data channel.** WinCC RT / FactoryTalk View ME / Experion Station all maintain a persistent data feed up to the L3 SCADA server (WinCC SCADA, FactoryTalk View SE, Experion PKS Server). A compromised L2 runtime is therefore an authenticated client against the L3 SCADA — pivot upward via OPC UA, FT Linx, or CDA without ever touching L3.5 firewall rules.
4. **Compromised HMI panel as cheap unmonitored beach-head on a flat OT VLAN.** Vendor HMI panels (Comfort, PanelView Plus, Magelis) are rarely covered by EDR, rarely patched, and frequently share a VLAN with PLCs. A panel firmware swap or web-UI auth bypass yields persistent foothold with credible protocol traffic — the lowest-cost L2 entry in a flat OT network.

Sources

- [Siemens ProductCERT advisory index](#)
- [Rockwell Automation Trust Center — Security Advisories](#)
- [Schneider Electric PSIRT / Cybersecurity Support Portal](#)
- [Honeywell PSIRT / Security Notifications](#)
- [CISA ICSA-24-018-01 — FactoryTalk Service Platform CVE-2024-21915](#)
- [CISA ICSA-23-193-01 — FactoryTalk View ME family](#)
- [CISA ICSA-23-061-02 — Honeywell Experion PKS / LX / PlantCruise \(ICEFALL\)](#)
- [CISA ICSA-21-294-02 — Honeywell Experion PKS file upload / argument injection](#)
- [Claroty Team82 — ICEFALL Continues: Broken Trust, Broken Code \(Experion\)](#)
- [Forescout OT:ICEFALL research](#)
- [Dragos — ICS Cybersecurity Year in Review](#)
- [Armis — research index](#)
- [MITRE ATT&CK for ICS — T0832 Manipulation of View](#)
- [MITRE ATT&CK for ICS — T0836 Modify Parameter](#)
- [MITRE ATT&CK for ICS — T0831 Manipulation of Control](#)
- [MITRE ATT&CK for ICS — T0859 Valid Accounts](#)
- [MITRE ATT&CK for ICS — T0812 Default Credentials](#)
- [IEC 62443 / Purdue reference model — ISA-99 zones & conduits](#)
- [CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection \(2024\)](#)
- Internal: [siemens brief](#), [rockwell brief](#), [schneider brief](#), [honeywell brief](#), [eaton brief](#) (shape template)